

Clase 159 — Fileless malware y living-off-the-land

Parte: **6 — Análisis de malware** · Fuente: *The Art of Memory Forensics* y MITRE ATT&CK  Duración estimada: **120 min** · Nivel: **Experto**

Objetivo

Analizar amenazas que apenas tocan el disco: malware **fileless** que vive en memoria o en el registro, y ataques **living-off-the-land (LOLBins)** que abusan de binarios legítimos del sistema. El alumno aprenderá a detectar y reconstruir estas técnicas con forense de memoria y telemetría, donde el análisis de archivos tradicional se queda ciego.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Definir** malware fileless y sus mecanismos de persistencia sin archivo.
- 2. **Reconocer** LOLBins comunes y cómo se abusan (LOLBAS).
- 3. **Detectar** código solo en memoria con forense (Volatility).
- 4. **Reconstruir** la cadena desde la telemetría (Sysmon/EDR/ScriptBlock).
- 5. **Proponer** detecciones centradas en comportamiento, no en archivos.

Temas

#	Tema	Por qué importa
1	Qué es fileless y por qué evade	Sin archivo, menos detección AV
2	Persistencia sin archivo (registro, WMI)	Sobrevive sin binario en disco
3	LOLBins y LOLBAS	Abuso de binarios firmados
4	Inyección y ejecución en memoria	Payload nunca toca disco
5	Forense de memoria para fileless	Única fuente de evidencia
6	Telemetría: Sysmon, ETW, EDR	Reconstrucción de la cadena
7	Detección por comportamiento	Estrategia frente a fileless

Definiciones y características

- **Fileless malware:** ejecuta principalmente en memoria, con poca o nula huella en disco. Característica clave: **evasión de AV de archivos**.
- **LOLBin/LOLBAS:** binario legítimo del SO abusado con fines maliciosos. Característica clave: **confianza heredada**.
- **Persistencia WMI:** suscripciones a eventos WMI para ejecutar código. Característica clave: **sin archivo visible**.

- **Registro como almacenamiento:** payloads guardados en claves del registro. Característica clave: **oculto y persistente**.
- **In-memory injection:** cargar y ejecutar payload en RAM. Característica clave: **nada que escanear en disco**.

Herramientas y preparación

- **Volatility 3** (`malfind` , `windows.registry` , `windows.svcscan` , `windows.wmi`).
- **Sysmon** (Event IDs 1, 3, 7, 8, 11, 19–21) y **Event Viewer** (PowerShell 4104).
- Referencia **LOLBAS** (`lolbas-project.github.io`).
- **Autoruns**, **winpmem** para capturar RAM.

 **Nota ética y de seguridad:** las técnicas LOLBin y fileless se estudian para **detección y respuesta**. Detona en la VM aislada con captura de memoria y telemetría. No uses estas técnicas fuera de sistemas propios y autorizados.

Laboratorio guiado

1. Restaura `base-clean` , habilita **Sysmon** (config tipo SwiftOnSecurity) y **ScriptBlock Logging**.
2. Detona un caso fileless (o reproduce una cadena LOLBin controlada). Captura RAM con `winpmem` al final.
3. Con Volatility, `windows.malfind` para regiones RWX inyectadas: identifica el payload en memoria y vuélcalo para analizarlo.
4. Busca persistencia sin archivo: `windows.registry.printkey` en claves `Run` /servicios con payloads codificados, y suscripciones **WMI** (`__EventFilter` / `CommandLineEventConsumer`).
5. Revisa la telemetría: en Sysmon, procesos hijos de Office/ `explorer` que lanzan `powershell` , `mshta` , `rundll32` , `regsvr32` con argumentos sospechosos (LOLBins). Anota los Event IDs.
6. Reconstruye la cadena de ejecución uniendo memoria + Sysmon + ScriptBlock (Event 4104).
7. Propón detecciones por comportamiento (p. ej. `rundll32` sin DLL, `regsvr32` con URL, WMI consumer nuevo) y mapea a ATT&CK (`T1218` , `T1546.003` , `T1055`).

Ejercicios

1. Explica por qué el AV de archivos falla contra fileless.
2. Enumera 6 LOLBins y su abuso típico (con Event Sysmon esperado).
3. Detecta un payload en memoria con `malfind` y vuélcalo.
4. Identifica una persistencia WMI y descríbela.
5. Escribe una regla de detección para `regsvr32` con URL remota.
6. Reconstruye una cadena LOLBin desde logs de Sysmon.

Reto verificable

Analiza una cadena fileless/LOLBin y entrega su **reconstrucción** con: payload en memoria volcado, persistencia sin archivo identificada, LOLBins abusados y detecciones por comportamiento mapeadas a ATT&CK. **Criterio de aceptación:** presentas evidencia de memoria (`malfind`/registro/WMI) y de telemetría

(Sysmon/4104) que juntas explican la cadena completa, más al menos dos detecciones por comportamiento implementables.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"No hay malware" en disco	Es fileless; analiza memoria y registro
Sin telemetría útil	Sysmon/logging no configurados; habilítalos antes de detonar
LOLBin parece legítimo	Revisa argumentos y proceso padre, no solo el binario
Persistencia no aparece	Busca WMI y registro, no solo tareas/servicios con archivo
Payload perdido al reiniciar	Fileless no persiste el binario; captura RAM en caliente

Preguntas frecuentes

? ¿Fileless significa sin ningún rastro? No. Deja rastro en memoria, registro, WMI y telemetría; solo evita el archivo ejecutable clásico en disco.

? ¿Cómo detecto abuso de LOLBins? Por comportamiento: relaciones proceso-padre inusuales, argumentos anómalos y accesos de red desde binarios que normalmente no los hacen.

? ¿La memoria es imprescindible aquí? Sí. Para fileless, el volcado de RAM suele ser la única fuente que contiene el payload real.

Referencias

- Ligh et al., *The Art of Memory Forensics*.
- LOLBAS Project. <https://lolbas-project.github.io>
- MITRE ATT&CK — Signed Binary Proxy Execution (T1218). <https://attack.mitre.org/techniques/T1218/>
- Sysmon. <https://learn.microsoft.com/sysinternals/downloads/sysmon>

Siguiente clase

[Clase 160 - Reporte de analisis de malware](#)